

INFORME DE INCIDENTE DE SEGURIDAD

Título del reporte: Inyección SQL en la aplicación web DVWA

Introducción: Este informe detalla un incidente de seguridad detectado en la aplicación web Damn Vulnerable Web Application (DVWA), donde se ha identificado una vulnerabilidad de inyección SQL. La vulnerabilidad permite a un atacante manipular las consultas a la base de datos, lo que representa un riesgo significativo para la confidencialidad e integridad de la información almacenada.

Descripción del incidente: Se ha identificado una vulnerabilidad de inyección SQL en la funcionalidad de búsqueda de usuario dentro de la aplicación DVWA. Mediante la inserción de una consulta SQL maliciosa, un atacante puede obtener información confidencial de la base de datos sin necesidad de autenticación avanzada. Este fallo de seguridad compromete la seguridad del sistema y puede ser explotado para acceder a datos sensibles.

Proceso de reproducción:

1. Acceder a la interfaz de búsqueda de usuarios en DVWA.
 2. Ingresar la siguiente consulta en el campo de búsqueda:
`1' OR '1'='1`
 3. Enviar la solicitud.
 4. Como resultado, la aplicación devuelve todos los registros de la base de datos, en lugar de un único usuario específico.
 5. Se confirma la vulnerabilidad al observar datos de múltiples usuarios en la respuesta.
-

Impacto del incidente:

- **Confidencialidad:** Información sensible de usuarios queda expuesta, lo que puede facilitar ataques adicionales.
 - **Integridad:** Un atacante podría modificar o eliminar registros en la base de datos.
 - **Disponibilidad:** Un uso malintencionado de la vulnerabilidad podría afectar la operatividad de la base de datos.
 - **Cumplimiento:** Esta vulnerabilidad viola principios de seguridad definidos en normativas como la ISO 27001 y GDPR.
-

Recomendaciones:

1. **Implementar Prepared Statements:** Evita que los datos ingresados por el usuario se interpreten como código SQL.
2. **Validación de entradas:** Aplicar filtrado y saneamiento de datos para evitar la inyección de caracteres maliciosos.
3. **Restricción de permisos:** Limitar los privilegios de los usuarios en la base de datos para minimizar riesgos en caso de explotación.
4. **Registro y monitoreo:** Implementar sistemas de detección de intrusos (IDS) y auditoría de logs para identificar intentos de ataque.
5. **Actualización y parches:** Asegurar que la aplicación y la base de datos estén actualizadas con las últimas medidas de seguridad.

Conclusión: El presente informe evidencia una vulnerabilidad de inyección SQL en la aplicación DVWA, la cual expone información sensible y representa un alto riesgo para la seguridad del sistema. Se recomienda la implementación de controles adecuados para mitigar este riesgo y fortalecer la postura de seguridad de la aplicación. La aplicación de buenas prácticas en la gestión de seguridad de la información, alineadas con la norma ISO 27001, es fundamental para prevenir futuros incidentes.